Penetration Testing Report Template

Student Assessment Template

Student Name	[Insert your name]
Student ID	23249815
Unit	ISEC6005
Assessment Title	Final Exam Part 2 - Report
Target Machine	[Insert target Name/IP]
Date Submitted	[Insert date]

Important: This report must present findings responsibly. Include only authorised testing activity, clear evidence, impact, and remediation. Long command histories should be moved to the appendix.

REMINDER – what to put here (from the boxes you practised): Use this for a web-enumeration box (like Vesta / Lensora / H2forge). [TARGET-IP] = your box IP; [PORT] = the web port from nmap (e.g. 80 / 8080 / 9999); [PATH] = the hidden folder you find with gobuster or by following links (e.g. /assets/); [FILE] = the file in that folder holding the flag (e.g. flag.txt); [WORDLIST] = your gobuster wordlist.

Report Sections

1. Executive Summary
2. Scope and Rules of Engagement
3. Testing Methodology
4. Summary of Findings
5. Detailed Findings
6. Attack Path Summary
7. Remediation Plan
8. Conclusion
9. Appendix A. Technical Evidence
10. Appendix B. References

1. Executive Summary

During the authorised assessment of the target web host ([TARGET-IP]), enumeration of the web service on port [PORT] identified an information-disclosure weakness. Directory indexing was enabled on the [PATH e.g. /assets/] path, which returned a browsable list of its files; one of these, [FILE e.g. flag.txt], was retrievable directly and contained confidential data. An unauthenticated attacker able to reach the site could obtain this information with nothing more than a web browser. The highest risk is the sensitive-file disclosure (rated Medium). The main attack path is: web enumeration → directory listing → retrieval of a sensitive file. The primary root cause is a web-server misconfiguration combined with a sensitive file left in a web-accessible location.

Area	Student Entry	Guidance
Overall Risk	Medium	Choose one overall rating and

		justify it briefly.
Main Impact	An unauthenticated attacker can discover and download sensitive files from the web server.	Describe what could happen to the system or organisation.
Primary Root Cause	Security misconfiguration – directory listing enabled and sensitive files left in a web-accessible location.	Example: misconfiguration, weak access control, exposed credentials.
Top Remediation Priority	Disable directory listing and remove sensitive files from the web root.	State what should be fixed first and why.

2. Scope and Rules of Engagement

2.1 Scope

Asset / Host	IP / URL	Service(s)	In Scope?
[TARGET-HOST e.g. Lensora]	http://[TARGET-IP]:[PORT]/	HTTP ([PORT])	Yes

2.2 Rules of Engagement

- ☐ Testing was conducted only against authorised targets.
- ☐ Testing avoided unnecessary service disruption.
- ☐ Evidence was recorded for each finding.
- ☐ Sensitive data was handled responsibly and not disclosed unnecessarily.
- ☐ No persistence was installed unless explicitly required by the lab instructions.

3. Testing Methodology

Phase	Purpose	Evidence to Include
Reconnaissance	Find the web port(s) and identify the web stack.	`nmap -p- -sV [TARGET-IP]` `(find web port [PORT])`
Enumeration	Discover hidden paths/files (gobuster, links, robots.txt).	`whatweb http://[TARGET-IP]:[PORT]/ ; gobuster dir ...` `(find [PATH])`
Vulnerability Analysis	Confirm directory listing or an unprotected sensitive file.	`curl .../[PATH] returns a directory listing = indexing enabled`
Exploitation / Validation	Download the exposed file to obtain the flag.	`curl http://[TARGET-IP]:[PORT] [PATH][FILE] (download flag`

		file)
Privilege Escalation	Reuse any disclosed credentials against another service.	If creds were found, reuse against another service (evil-winrm/ssh)
Remediation Advice	Explain how to disable indexing and enforce access control.	Options -Indexes ; auth on sensitive paths ; remove files from web root

4. Summary of Findings

ID	Finding	Risk	Affected Asset	Status
F-01	Sensitive Information Disclosure via Directory Listing	Medium	[TARGET-IP] ([PORT])	Open
F-02	Sensitive File Reachable Without Authentication	Medium	[TARGET-IP] ([PORT])	Open

REMINDER (Summary of Findings): Example for this box: F-01 = Sensitive Information Disclosure via Directory Listing (Medium). Add F-02 = Sensitive File Reachable Without Authentication only if you also reached the intermediate flag; delete the unused F-03–F-05 rows.

5. Detailed Findings

REMINDER (Detailed Findings): Example for this box: Finding 1 = Sensitive Information Disclosure via Directory Listing. Replace the Evidence block with YOUR own command output / screenshots. Keep Finding 2 (Sensitive File Reachable Without Authentication) only if you reached the intermediate flag by reusing credentials – otherwise delete it.

Finding 1: Sensitive Information Disclosure via Directory Listing

Risk Rating	Medium
Affected Asset(s)	http://[TARGET-IP]:[PORT][PATH]
Vulnerability Type	Security misconfiguration – directory listing enabled
Evidence Reference	E-01, E-02
Business Impact	An attacker can browse and download files that should not be publicly accessible.
Remediation Priority	Immediate

Description

The web server on port [PORT] has directory indexing (automatic directory listing) enabled on [PATH]. Requesting that path returns a full, browsable list of the files it contains instead of a 403/404 response. One listed file, [FILE], held sensitive data and was downloadable without any authentication. The weakness is that directory browsing was left enabled and a sensitive file was placed in a web-reachable folder with no access control, so the application relies on files being unlinked rather than enforcing authentication. (On exam day, change [TARGET-IP], [PORT], [PATH] and [FILE] to what you find – the explanation of the weakness stays the same.)

Evidence

```
nmap -p- -sV [TARGET-IP]                          # find the web port(s)
whatweb http://[TARGET-IP]:[PORT]/                # identify the web stack
gobuster dir -u http://[TARGET-IP]:[PORT]/ -w [WORDLIST]   # discover [PATH]
curl http://[TARGET-IP]:[PORT][PATH]              # directory listing is returned
curl http://[TARGET-IP]:[PORT][PATH][FILE]        # retrieve the file -> flag/creds
```

Impact

Directory listing exposes every file in the folder, not only the one that held the flag – configuration files, backups, source code (.git) or credential files are commonly found the same way, and any credentials recovered can unlock other services and deepen the compromise. In business terms this is an unauthorised disclosure of confidential information that can lead to data breach, reputational damage and regulatory exposure.

Recommendation

Disable directory indexing on the web server (Options -Indexes in Apache, turn off Directory Browsing in IIS, autoindex off in nginx); enforce authentication/authorisation on sensitive resources rather than relying on them being unlinked; remove sensitive files from the web root entirely; and add server-side access checks on every protected object.

Verification After Fix

Re-request http://[TARGET-IP]:[PORT][PATH] – it should now return 403 Forbidden (or 404) instead of a listing, and the sensitive file should no longer be retrievable without valid credentials.

Finding 2: Sensitive File Reachable Without Authentication

Risk Rating	Medium
Affected Asset(s)	http://[TARGET-IP]:[PORT][PATH][FILE]
Vulnerability Type	Broken access control / information disclosure
Evidence Reference	E-02
Business Impact	Confidential data is readable by any unauthenticated user.
Remediation Priority	Immediate

Description

The file [FILE] is served directly over HTTP with no authentication or authorisation check, so any user who knows or discovers the path can read it. The weakness is missing access control on a sensitive resource. (If your box exposes only the directory listing, you can merge this into Finding 1 and remove this one.)

Evidence

```
curl http://[TARGET-IP]:[PORT][PATH][FILE]      # returns the file contents with no login
# also check: robots.txt, HTML source comments, and follow every link on the site
```

Impact

Sensitive data is disclosed to anyone able to reach the site. Depending on the file, this can include credentials, internal notes or configuration, which may enable further access.

Recommendation

Place sensitive resources behind authentication and authorisation; do not rely on obscure paths; remove sensitive files from the web root; and use non-guessable identifiers only as defence-in-depth, never as the sole control.

Verification After Fix

Request the file without credentials – it should return 401/403, and only authorised users should be able to read it.

6. Attack Path Summary

Step	Evidence	Security Meaning
Initial access / foothold	nmap -p- -sV [TARGET-IP]	Identified the web service running on port [PORT].
Local enumeration	gobuster / browse / follow links	Discovered the hidden path [PATH] on the web server.
Credential or configuration weakness	curl http://[TARGET-IP]:[PORT][PATH]	Directory listing was enabled, revealing the files in the folder.
Service or application abuse	curl ...[PATH][FILE]	Retrieved the sensitive file without authentication.
Privilege escalation proof	–	(If creds were found) reused them against another service for the higher-privilege flag.

Final impact	–	Confidential data disclosed over the web with no authentication required.

Attack Path Diagram

Web enumeration (nmap/gobuster) → directory listing on [PATH] → download [FILE] → sensitive data / flag disclosed.

7. Remediation Plan

Priority	Finding ID	Recommended Action	Owner	Verification Method
Immediate	F-01	Disable directory indexing on port [PORT] and remove the exposed file from the web root.	Web/ Infrastructure team	Re-request the folder – expect 403/404.
Immediate	F-02	Enforce authentication/authorisation on sensitive paths.	Web team	Request the file without credentials – expect 401/403.
Long-term	–	Adopt a hardened web-server baseline and review the web root for other exposed files (backups, .git, configs).	Security team	Periodic content review.

8. Conclusion

The assessment confirmed that the web server disclosed sensitive data without authentication, caused by directory indexing being enabled and a confidential file left in a web-accessible location. Although simple to exploit, it is a genuine confidentiality risk. Disabling directory listing, removing the file and enforcing access control fully remediate the issue. All testing stayed within the authorised scope and no data was altered or destroyed.

Appendix A. Technical Evidence

Use this appendix for detailed command output, screenshots, and supporting notes. Keep the main report concise.

Evidence ID	Command / Source	Screenshot / Output	Purpose
E-01	nmap -p- -sV [TARGET-IP]	[screenshot]	Confirms the web service and port.
E-02	curl http://[TARGET-IP]:[PORT][PATH]	[screenshot]	Shows directory listing enabled and the sensitive file.
E-03	curl ...[PATH][FILE]	[screenshot]	Shows the file contents retrieved without authentication.

Appendix B. References

OWASP Web Security Testing Guide – configuration and information-disclosure testing; OWASP Top 10 A05 Security Misconfiguration and A01 Broken Access Control; web-server hardening documentation.

Student Submission Checklist

- ☐ Executive summary is written for a non-technical reader.
- ☐ Each finding includes risk, evidence, impact, and remediation.
- ☐ Screenshots are labelled and referenced in the text.
- ☐ Only authorised testing activity is included.
- ☐ Sensitive credentials are redacted unless required by assessment instructions.
- ☐ The final report is professional, concise, and free of unnecessary terminal history.